



PAI-1. IntegriDos

Verificadores de Integridad
en la Transmisión para
Entidad Financiera



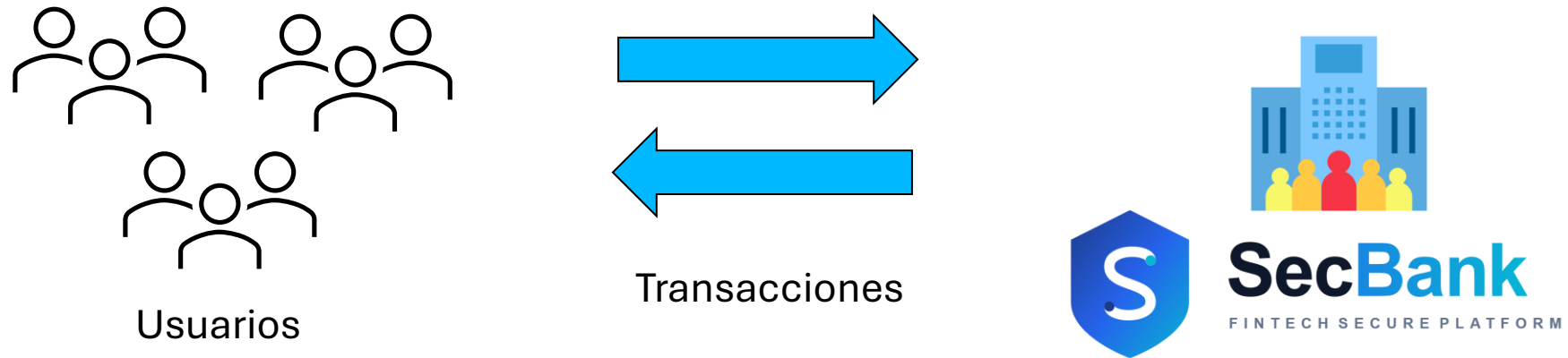
PAI-1. INTEGRIDOS: VERIFICADORES DE INTEGRIDAD EN LA TRANSMISIÓN PARA ENTIDAD FINANCIERA

Índice

1. Contexto
2. Problemas de seguridad
3. Objetivos y requisitos
4. Entrega

PAI-1. INTEGRIDOS: VERIFICADORES DE INTEGRIDAD EN LA TRANSMISIÓN PARA ENTIDAD FINANCIERA

Contexto



PAI-1. INTEGRIDOS: VERIFICADORES DE INTEGRIDAD EN LA TRANSMISIÓN PARA ENTIDAD FINANCIERA

Contexto



PAI-1. INTEGRIDOS: VERIFICADORES DE INTEGRIDAD EN LA TRANSMISIÓN PARA ENTIDAD FINANCIERA

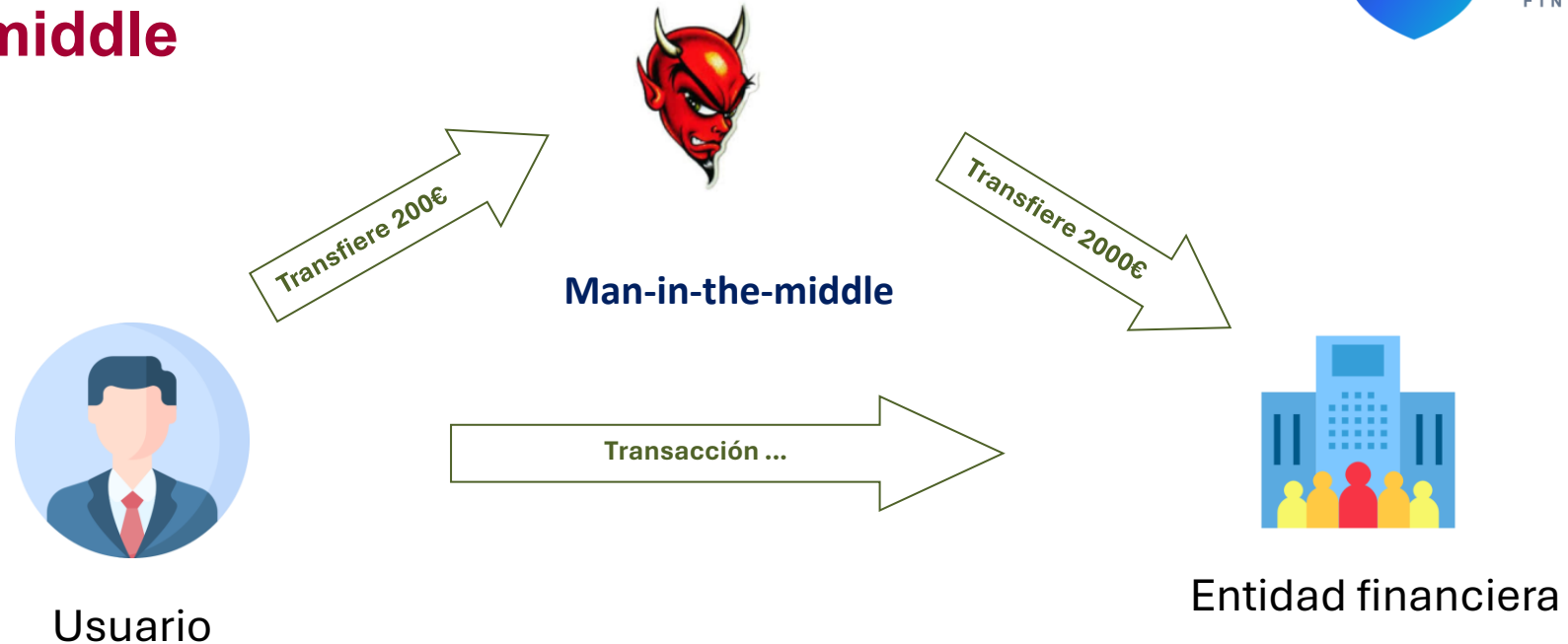
Índice

1. Contexto
2. Problemas de seguridad
3. Objetivos y requisitos
4. Entrega

PAI-1. INTEGRIDOS: VERIFICADORES DE INTEGRIDAD EN LA TRANSMISIÓN PARA ENTIDAD FINANCIERA

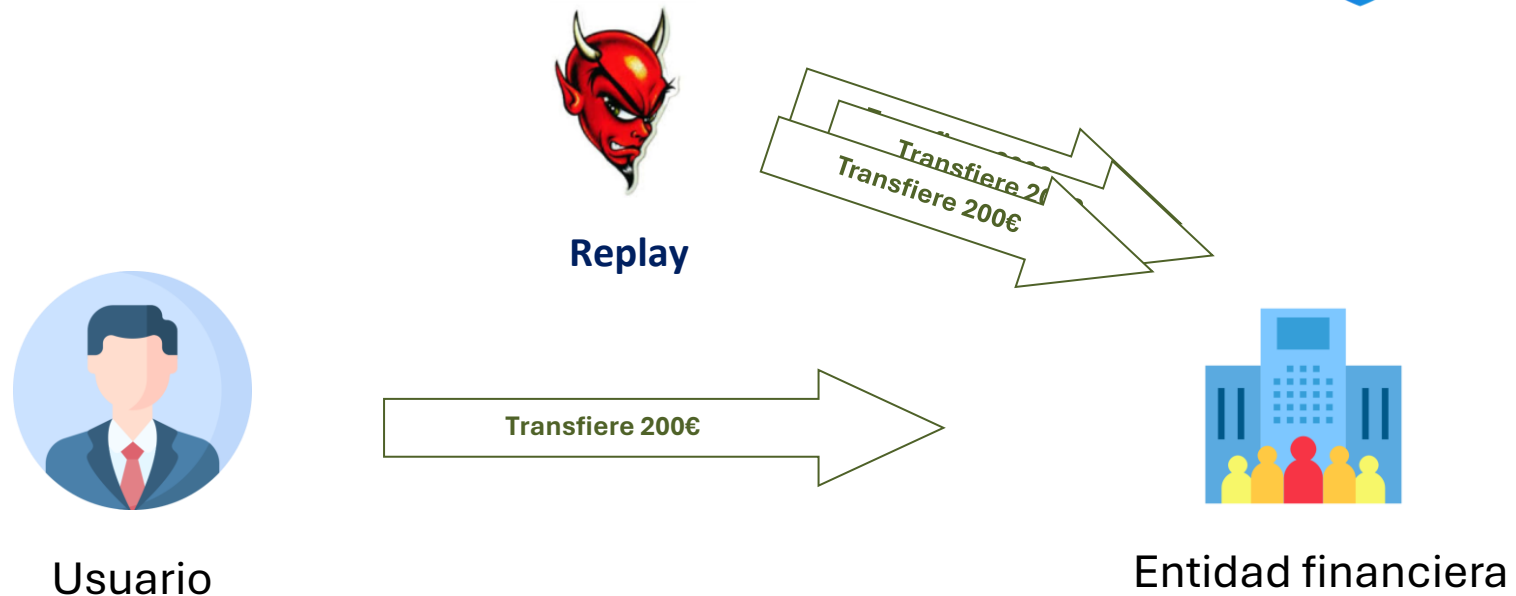
Problemas de seguridad

Man-in-the-middle



PAI-1. INTEGRIDOS: VERIFICADORES DE INTEGRIDAD EN LA TRANSMISIÓN PARA ENTIDAD FINANCIERA

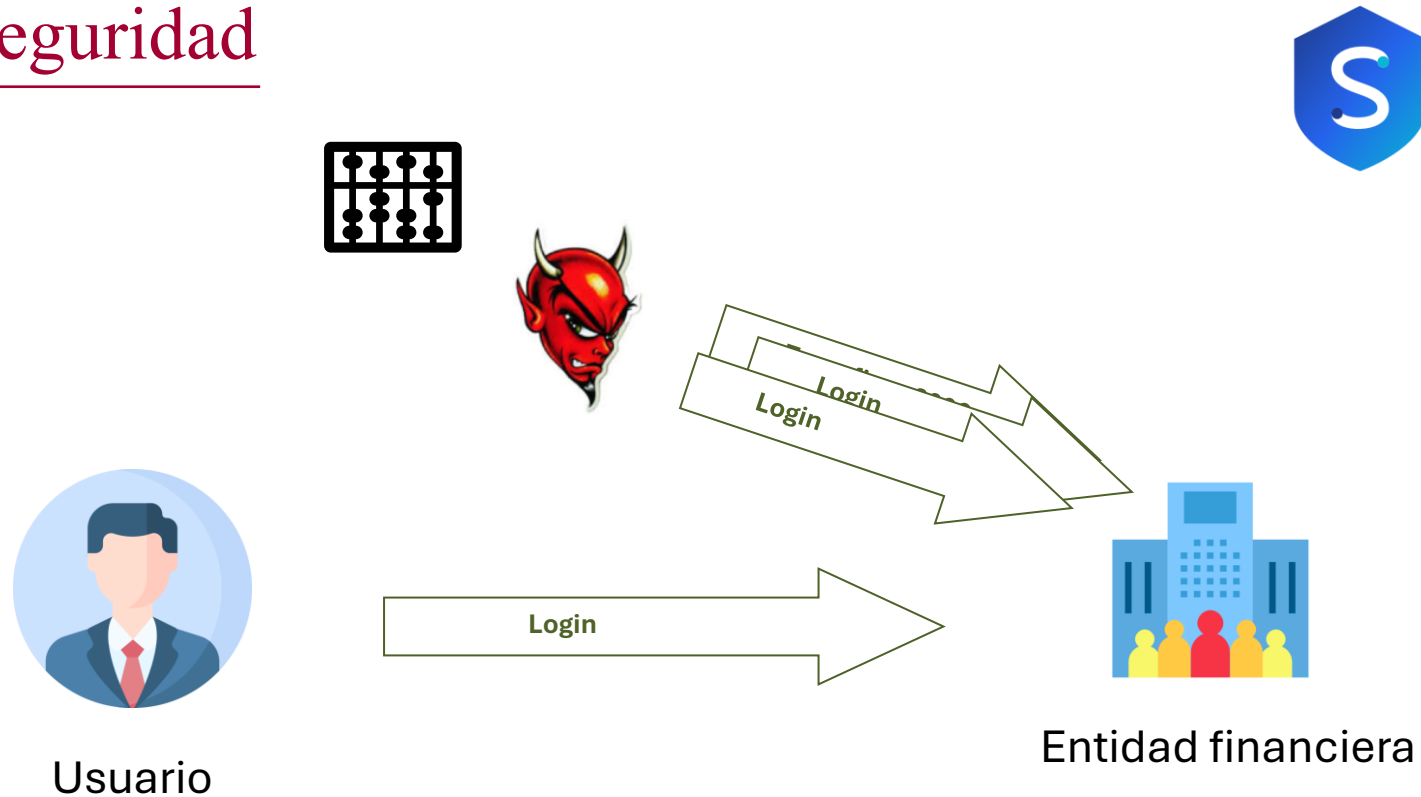
Problemas de seguridad



PAI-1. INTEGRIDOS: VERIFICADORES DE INTEGRIDAD EN LA TRANSMISIÓN PARA ENTIDAD FINANCIERA

Problemas de seguridad

Key derivation



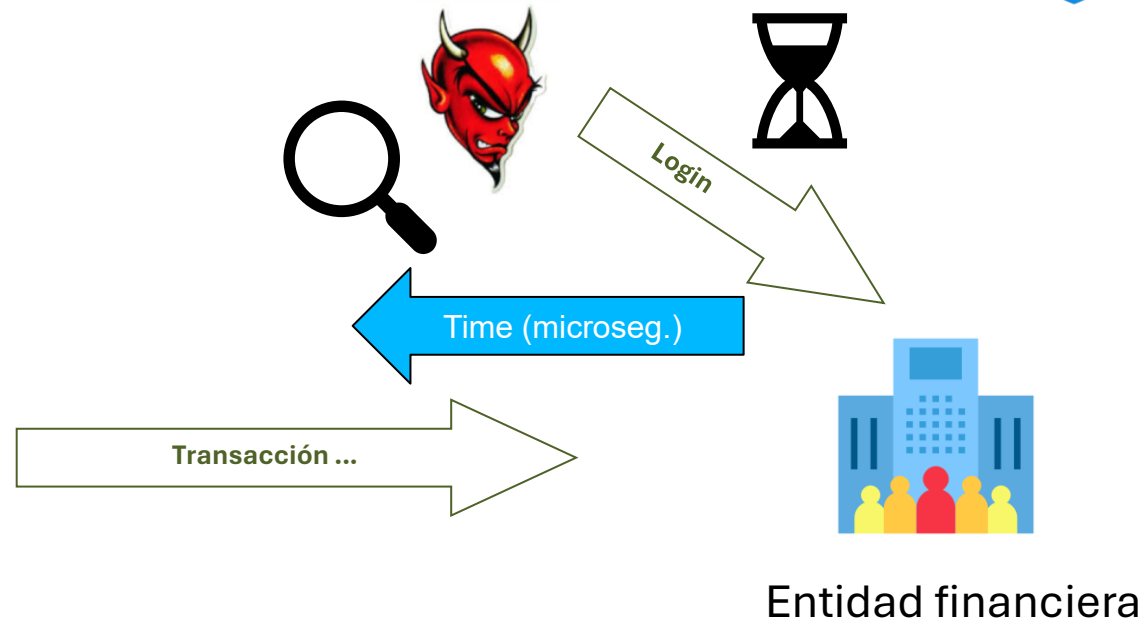
PAI-1. INTEGRIDOS: VERIFICADORES DE INTEGRIDAD EN LA TRANSMISIÓN PARA ENTIDAD FINANCIERA

Problemas de seguridad

Lateral Channel



Usuario



PAI-1. INTEGRIDOS: VERIFICADORES DE INTEGRIDAD EN LA TRANSMISIÓN PARA ENTIDAD FINANCIERA

Índice

1. Contexto
2. Problemas de seguridad
3. Objetivos y requisitos
4. Entrega

PAI-1. INTEGRIDOS: VERIFICADORES DE INTEGRIDAD EN LA TRANSMISIÓN PARA ENTIDAD FINANCIERA

Política de Seguridad



Key size

"En todas las transacciones por medios electrónicos no seguros se debe conservar la integridad y autenticidad de las comunicaciones a nivel de aplicación. El servidor debe asegurar la integridad de la información de los usuarios registrados, de las sesiones activas y de cada una de las órdenes de transferencia procesadas."

HMAC



**0110
1001
1010**

Hashing



PAI-1. INTEGRIDOS: VERIFICADORES DE INTEGRIDAD EN LA TRANSMISIÓN PARA ENTIDAD FINANCIERA

Objetivos



Desarrollar un sistema cliente-servidor distribuido que permita el envío de credenciales y mensajes de transacciones bancarias en cumplimiento estricto con la Política de Seguridad.



Implementar en el servidor un mecanismo seguro de registro, almacenamiento y verificación de credenciales de usuario mediante funciones de derivación adaptativas y sal aleatoria.



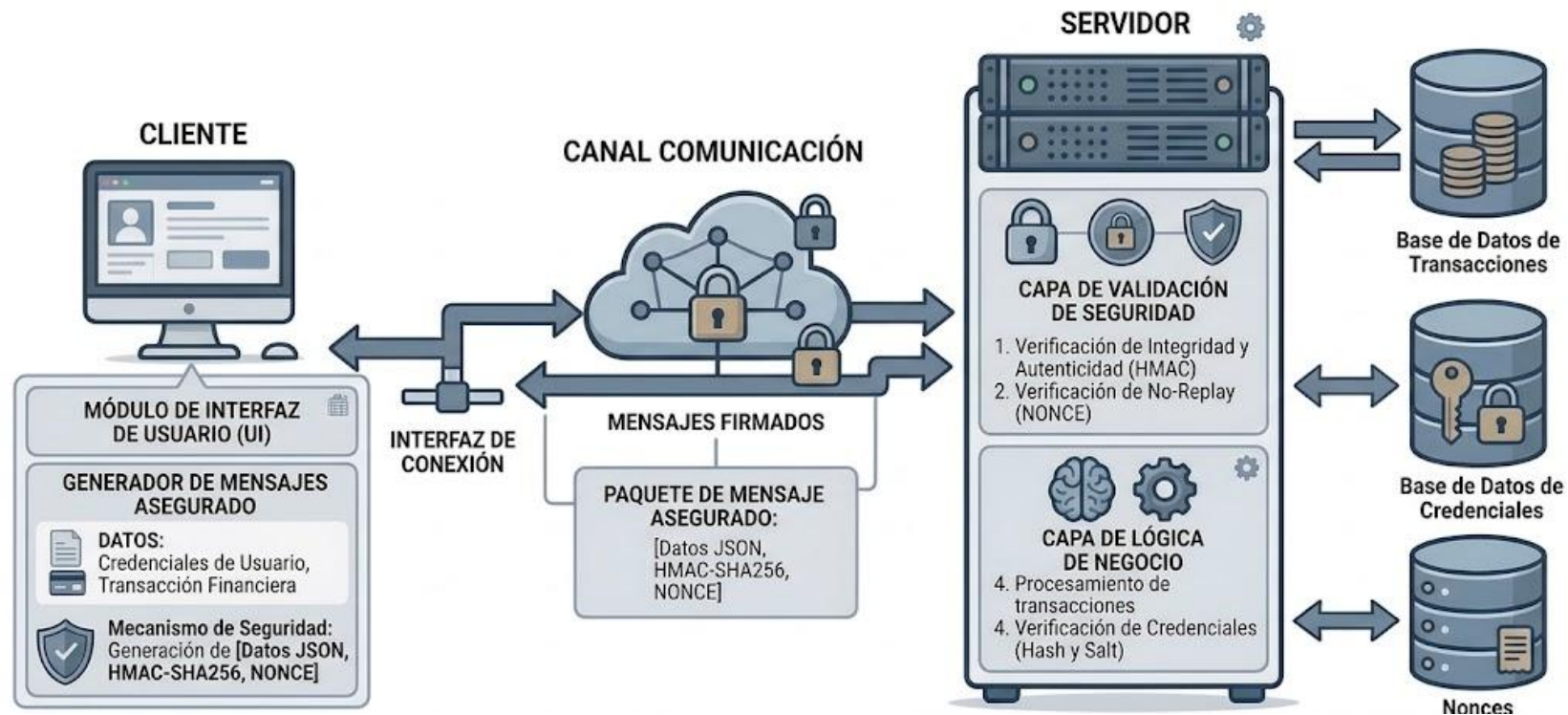
Desarrollar un verificador de integridad para los mensajes de transferencia bancaria transmitidos por redes públicas, previniendo ataques MitM, Replay, Key Derivation y de Canal Lateral de Tiempo mediante el uso de firmas con HMAC, NONCEs y Timestamps, tamaños de clave adecuados y comparadores en tiempo constante.



Generar evidencias técnicas mediante capturas de tráfico de red (archivos .pcap) y análisis de tiempo para auditar el comportamiento del sistema ante intentos de manipulación o reintervención.

PAI-1. INTEGRIDOS: VERIFICADORES DE INTEGRIDAD EN LA TRANSMISIÓN PARA ENTIDAD FINANCIERA

Recomendaciones



PAI-1. IntegriDos: Verificadores de Integridad en la Transmisión para Entidad Financiera

Recomendaciones

Gestión de Usuarios (Registro e Inicio de Sesión):

- Registro de nuevos usuarios con username y password.
- Base de datos inicial con usuarios pre-registrados para pruebas.
- Impedir el registro de usuarios duplicados.
- Manejar sesiones activas e imponer un mecanismo de cierre de sesión (Logout).

Transacciones (JSON), verificadas (integridad y autenticidad)

```
{  
  "tx_id": "UUIDv4",  
  "origin_account": "ES1234567890123456789012",  
  "destination_account": "ES9876543210987654321098",  
  "amount": 1500.50,  
  "currency": "EUR",  
  "timestamp": 1741690000  
}
```

PAI-1. INTEGRIDOS: VERIFICADORES DE INTEGRIDAD EN LA TRANSMISIÓN PARA ENTIDAD FINANCIERA

Recomendaciones



*Almacenamiento y
Verificación de
Credenciales*



*Garantía de
Integridad y
Autenticidad de
Transacciones*



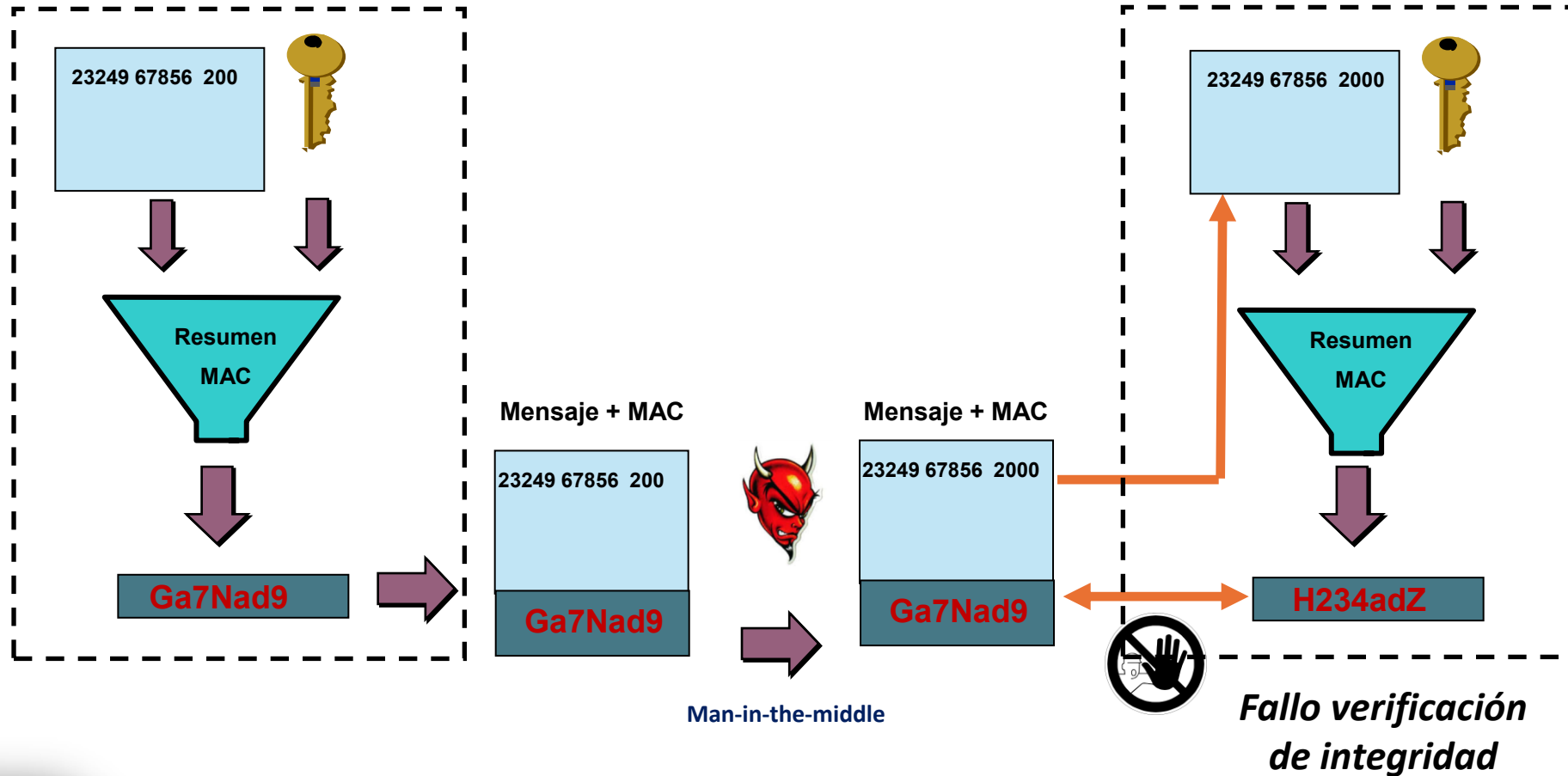
*Protección contra
Ataques de Replay*



*Mitigación de Canales
Laterales de Tiempo
(Timing Attacks)*

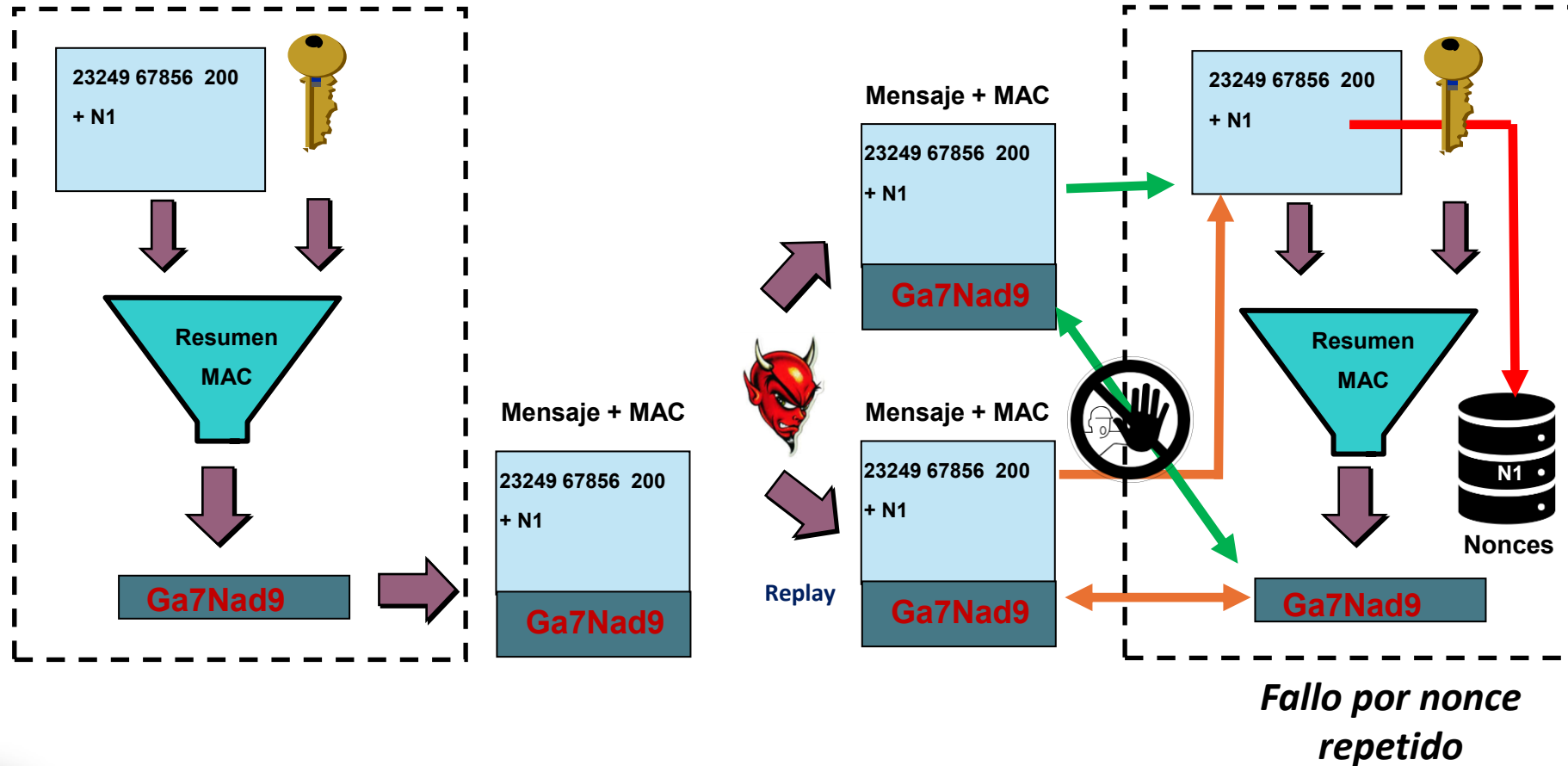
PAI-1. INTEGRIDOS: VERIFICADORES DE INTEGRIDAD EN LA TRANSMISIÓN PARA ENTIDAD FINANCIERA

Recomendaciones



PAI-1. INTEGRIDOS: VERIFICADORES DE INTEGRIDAD EN LA TRANSMISIÓN PARA ENTIDAD FINANCIERA

Recomendaciones



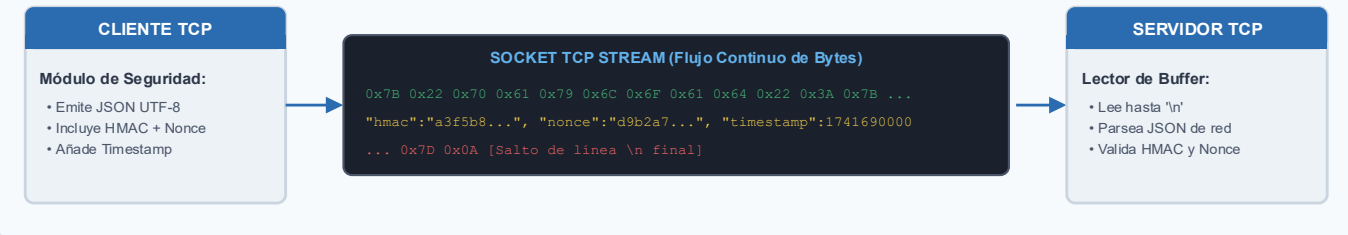
PAI-1. INTEGRIDOS: VERIFICADORES DE INTEGRIDAD EN LA TRANSMISIÓN PARA ENTIDAD FINANCIERA

Recomendaciones

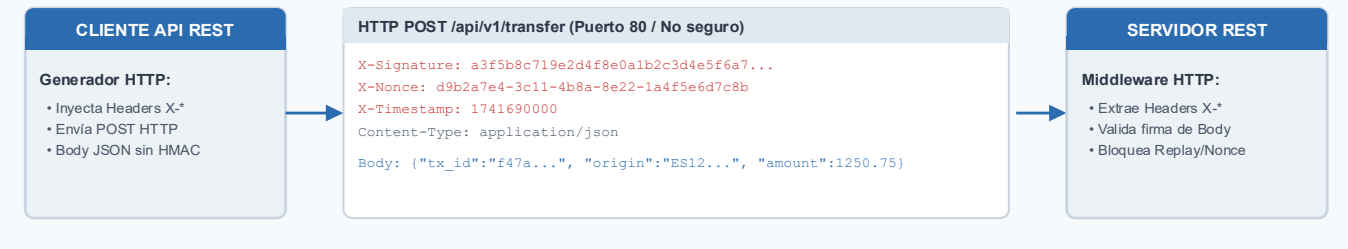
1. TCP “crudo”
2. API Rest (HTTP1.1 / POST)
3. gRPC (HTTP/2)

Modelos de Comunicación Cliente-Servidor Multitecnología (SecBank)

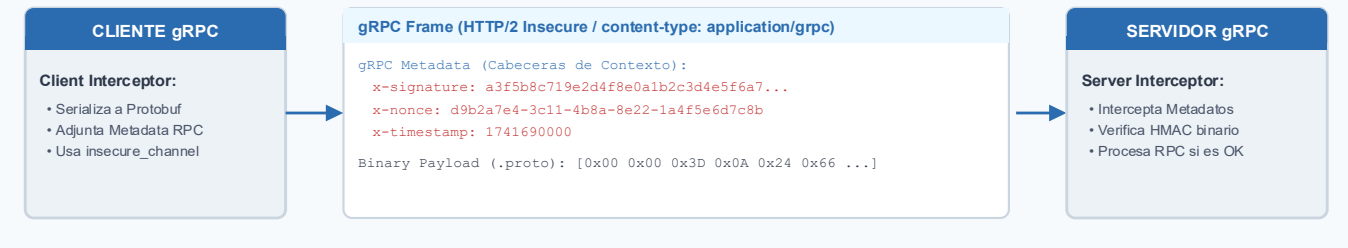
1. Opción A: Sockets TCP Crudos (Stream de Bytes en Texto Plano)



2. Opción B: API REST (HTTP / Peticiones con Cabeceras Personalizadas)



3. Opción C: gRPC / Protocol Buffers (Canal Inseguro HTTP/2 con Metadatos)



PAI-1. INTEGRIDOS: VERIFICADORES DE INTEGRIDAD EN LA TRANSMISIÓN PARA ENTIDAD FINANCIERA

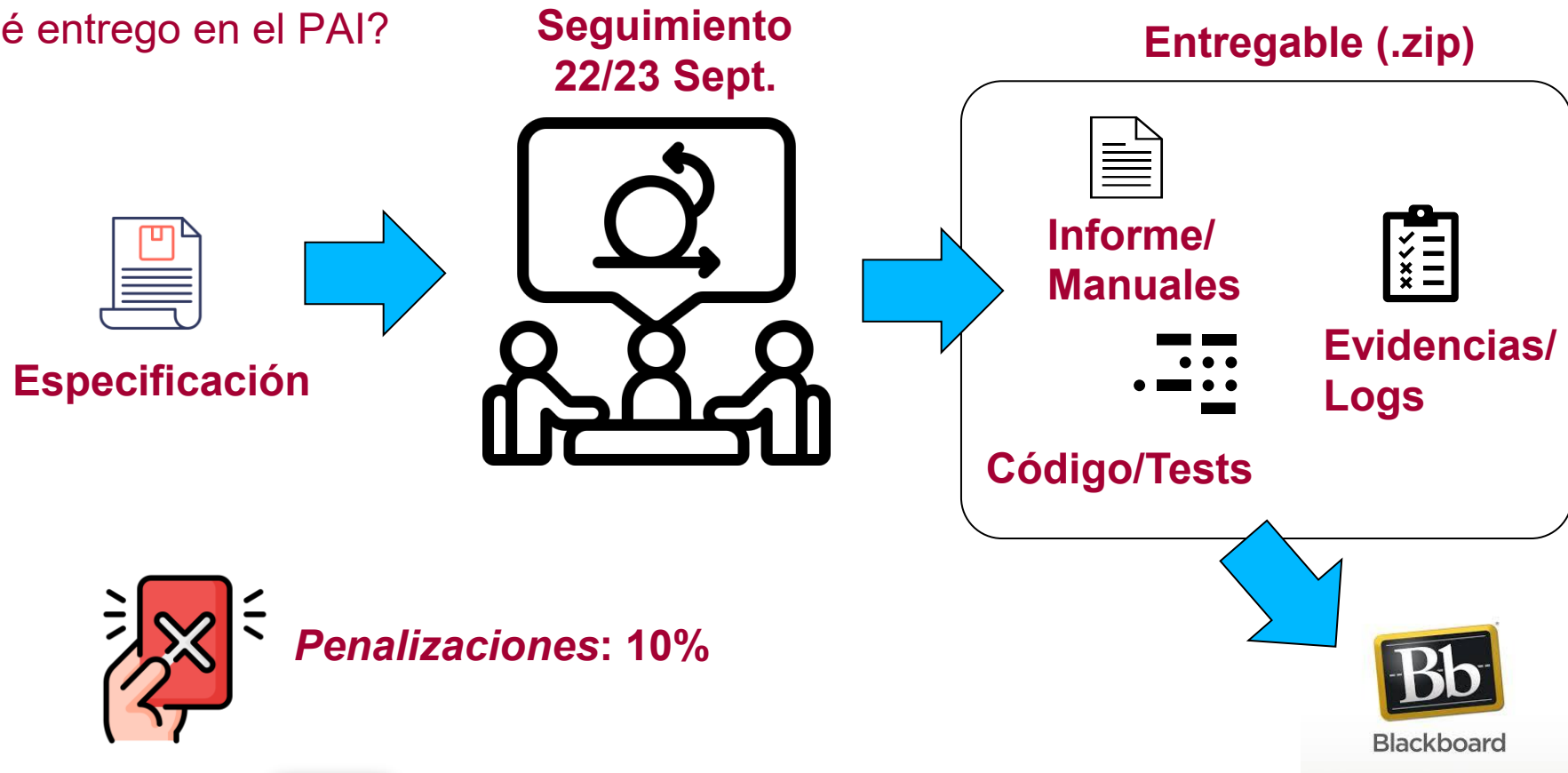
Índice

1. Contexto
2. Problemas de seguridad
3. Objetivos y requisitos
4. Entrega

PAI-1. INTEGRIDOS: VERIFICADORES DE INTEGRIDAD EN LA TRANSMISIÓN PARA ENTIDAD FINANCIERA

Entrega

¿Cómo y qué entrego en el PAI?



UNIVERSIDAD



SEVILLA

Deadline: 5 de octubre

PAI-1. INTEGRIDOS: VERIFICADORES DE INTEGRIDAD EN LA TRANSMISIÓN PARA ENTIDAD FINANCIERA

Entrega

¿Qué debo tener en cuenta?

- **IA:** Uso Ético y Responsable
- **Github** o **GitLab:** Gestiona tu código (lógica y tests)
- **Evidencias:** capturas de tráfico, logs, salida de los test, ...
- **Documentación:** Sigue las recomendaciones de estructura, cuida el formato, el estilo, la redacción, ...

PAI-1. INTEGRIDOS: VERIFICADORES DE INTEGRIDAD EN LA TRANSMISIÓN PARA ENTIDAD FINANCIERA

Rúbrica

Criterios	A (Completamente sat...	B (Muy satisfecho)	C (Satisfecho)  	D (Parcialmente satisf...	E (Insatisfecho)
Seguimiento	1 puntos Trabajo continuado durante las sesiones de todo el equipo. Se observa avances significativos en el desarrollo de la solución y actitud proactiva.	0,75 puntos Seguimiento constante en el aula con pequeñas fluctuaciones de miembros del equipo. Se observan avances en el desarrollo aunque todavía faltan bastantes aspectos esenciales por trabajar.	0,5 puntos Seguimiento básico en el aula con fluctuaciones de miembros del equipo. Aunque se aborda el trabajo pero se observan pocos avances en el desarrollo de la solución.	0,25 puntos Seguimiento básico en el aula con fluctuaciones de miembros del equipo. Se aborda el trabajo pero se observan pocos avances en el desarrollo de la solución.	0 puntos Ausencia continuada a sesiones de seguimiento.
1 puntos posibles					

PAI-1. INTEGRIDOS: VERIFICADORES DE INTEGRIDAD EN LA TRANSMISIÓN PARA ENTIDAD FINANCIERA

Rúbrica

Memoria/Informes/ Manuales	3 puntos Documentación excelente y exhaustiva: • Formato y estilos excelentes. • Diagrama claro de la arquitectura Cliente-Servidor adaptado a la tecnología elegida (Sockets TCP, REST o gRPC). • Justificación teórica rigurosa de los controles criptográficos. • Manual de despliegue reproducible paso a paso. • Análisis detallado de las capturas/logs para demostrar el correcto funcionamiento de los controles implementados. • Justificación reflexiva sobre el uso, validación y correcciones aplicadas al código generado por IA.	2,25 puntos Documentación completa y bien estructurada: • Formato y estilos bien definidos aunque existen algunos aspectos a mejorar. • Incluye diagramas claros de la arquitectura. • Describe adecuadamente el uso de HMAC, Nonces y almacenamiento seguro de claves. • Manual de despliegue ejecutable aunque con ciertos dificultades. • Adjunta Análisis detallado de las capturas/logs asociadas a los mensajes transmitidos. • Apartado de IA completo.	1,5 puntos Documentación funcional con carencias menores: • Defectos de formato y estilos detectados. • Diagrama básico pero incompleto en los detalles del flujo de datos. • Explica la seguridad de forma superficial (omite explicaciones como el impacto de ataques de canal lateral o la necesidad de la comparación en tiempo constante). • Capturas/Logs incluidas como imágenes sin análisis técnico. • Reflexión de IA genérica.	0,75 puntos Documentación deficiente: • Bastantes defectos de Formato y estilos detectados. • Falta de diagramas o esquemas desalineados con el código presentado. • Explicaciones criptográficas erróneas o confusas. • Sin instrucciones claras para ejecutar el proyecto ni análisis de capturas de red.	0 puntos Memoria no entregada, plagada, o que no alcanza los requisitos mínimos de estructura y contenido técnico.
3 puntos posibles					

PAI-1. INTEGRIDOS: VERIFICADORES DE INTEGRIDAD EN LA TRANSMISIÓN PARA ENTIDAD FINANCIERA

Rúbrica

Código/Test/Logs	6 puntos	4,5 puntos	3 puntos	1,5 puntos	0 puntos
	Implementación técnica impecable: • Restricción de Red: Ausencia total de TLS/HTTPS. • Integridad y Autenticidad: Implementación correcta de firmas sobre la carga útil (JSON o Protobuf). • Anti-Replay: Control eficaz de marca de tiempo (Timestamp) y registro persistente de Nonces. • Canales Laterales: Uso estricto de funciones de comparación en tiempo constante (secrets.compare_digest o equivalente). • Credenciales: Almacenamiento seguro usando Argon2id o PBKDF2 con Salt único por usuario. • Pruebas y Logs: Suite de pruebas que demuestra el rechazo de ataques de alteración (MitM) y repetición (Replay). Archivos .pcap válidos y legibles.	Implementación funcional con errores menores: • Cumple con todos los requisitos de seguridad en la capa de aplicación sin usar TLS. • Correcto cálculo de MACs, comprobación de Nonce y salting de contraseñas. • Pequeños fallos que no comprometen la seguridad (ej. tratamiento de excepciones al parsear tramas corruptas o purgado de nonces antiguos en memoria). • Pruebas funcionales y trazas/logs correctos.	Implementación funcional pero con debilidades técnicas: • El sistema funciona pero incluye vulnerabilidades en el código (ej. uso de comparadores de cadenas estándar == vulnerables a timing attacks, o timestamps sin ventana de validez límite). • Base de datos funcional pero con mal manejo del Salt o hashing débil. • Capturas tráfico/logs entregadas pero con tráfico incompleto.	Implementación con fallos graves: • Incumplimiento de Restricciones: El código utiliza TLS/HTTPS o librerías de transporte seguro por defecto. • Faltan controles criptográficos críticos (ej. no valida los Nonces, omite el MAC o usa algoritmos obsoletos como MD5/SHA1). • El código no pasa las pruebas básicas de modificación de mensajes.	Código que no ejecuta, ausencia total de controles de integridad y autenticidad, o código plagiado sin funcionamiento demostrable.
6 puntos posibles					



UNIVERSIDAD
D SEVILLA
1505